

(c) Narrativa explicativa para la Encuesta CVSS y Gestión de Vulnerabilidades

1. Introducción: del número mágico al mapa de riesgo

Durante años, el CVSS ha sido para muchos un número casi esotérico entre 0 y 10 que aparecía en informes, auditorías y boletines de seguridad.[web:53]

Con CVSS 4.0, el número deja de ser el protagonista único: entran en escena métricas Base, Threat, Environmental y Supplemental, que permiten aproximarse mucho más al concepto real de riesgo.[web:16][web:17][web:58]

Esta encuesta se sitúa precisamente en ese punto de inflexión: quiere saber cómo están usando las organizaciones españolas este lenguaje común para gestionar vulnerabilidades y construir resiliencia en un entorno regulatorio más exigente (NIS2, CRA y familia).[web:56][web:57][web:61]

2. Propósito: tomar el pulso a la madurez

El propósito principal es triple:

- **Medir el grado de adopción de CVSS (especialmente CVSS 4.0)** y de sus métricas avanzadas.
- **Comprender cómo se integra la gestión de vulnerabilidades en la práctica**, más allá de la teoría y los manuales.
- **Identificar brechas y palancas** para ayudar a organizaciones, reguladores y proveedores a elevar el nivel del juego.

Se trata de pasar del “sabemos que hay que parchear rápido” al “sabemos qué vulnerabilidades, dónde, con qué prioridad y por qué”.

3. Ejes narrativos de la encuesta

3.1. Madurez organizativa

Los primeros bloques exploran si la organización tiene un proceso estable para gestionar vulnerabilidades: si hay política, frecuencia, fuentes, responsables.[web:63]

Sin esta base, cualquier conversación sobre CVSS 4.0 sería como hablar de física cuántica sin haber aprobado álgebra.

3.2. CVSS como idioma común

La encuesta indaga qué versiones de CVSS se usan, quién las maneja y cómo se decide el grado de confianza en los scores externos.[web:53][web:58]

Se quiere entender si el CVSS se toma como dogma, se discute como hipótesis, o se ignora con una mezcla de resignación y humor negro.

3.3. La nueva gramática de CVSS 4.0

Se exploran explícitamente las métricas Base, Threat, Environmental y Supplemental:

- Si se revisan y recalculan.

- Si se incorporan datos de explotación real.
- Si se ajusta el impacto al contexto local.
- Si se atiende a factores como automatización, seguridad física o esfuerzo de recuperación.[web:16]
[web:17][web:55][web:58]

Es, por así decirlo, preguntar si estamos usando el piano completo o seguimos tocando con dos dedos.

3.4. Regulación como metrónomo

NIS2 y el CRA no son meros decorados legales: exigen procesos de vulnerability handling y evidencias de gestión de riesgos.[web:56][web:57][web:62]

La encuesta recoge hasta qué punto CVSS sirve como puente entre el mundo técnico y el de cumplimiento: si se usa para demostrar diligencia, justificar prioridades o dialogar con supervisores.

3.5. Indicadores, ROI y narrativa de valor

El cuestionario pregunta por indicadores, KPIs, reporting y modelos de ROI.[web:61]

En el fondo, apunta a una cuestión incómoda pero necesaria: ¿sabemos explicar, con números y con relatos convincentes, por qué invertir en gestionar vulnerabilidades es mejor que pagar después la factura de los incidentes?

4. Cómo leer los resultados

4.1. Más allá del aprobado/suspenso

La interpretación recomendada no es binaria, sino gradual.

Los índices de madurez (IGM) propuestos permiten ubicar a cada organización en un continuo, con comparaciones por sector, tamaño y obligación regulatoria.

4.2. Historias que los datos cuentan

Los datos cuantitativos deberán acompañarse de comentarios cualitativos (bloque 12) que ayuden a entender el contexto:

- Argumentos típicos de resistencia.
- Éxitos notables.
- Dilemas entre agilidad y seguridad.

Esto facilita construir narrativas de buenas prácticas y casos de uso, más allá de gráficos de barras.

4.3. Usos posibles

Los resultados pueden alimentar:

- Informes de situación país.
- Estrategias de formación y sensibilización.
- Guías sectoriales sobre cómo aprovechar CVSS 4.0.
- Diálogos entre supervisores, asociaciones sectoriales y operadores.

5. Tono y espíritu de la encuesta

Aunque el tema sea serio, el tono de algunas preguntas y opciones admite un leve guiño irónico. No se trata de ridiculizar, sino de invitar a respuestas honestas: reconocer que algo es “ad hoc” o “a ojo clínico” es el primer paso para mejorarlo.

La encuesta está diseñada como una herramienta de diagnóstico, no como un examen. Si ayuda a que algunos CISOs duerman un poco mejor (o, al menos, con preocupaciones mejor priorizadas), habrá cumplido su función.